An ISO 9001:2015 CERTIFIED company

VAPT Report for MOL SAME Website

Author Name: Rajesh Kumar,IST Team

Date Created: 15-July-2025

Table of Contents

1 EXECUTIVE SUMMARY 3

2 SCOPE 3

3 TESTING METHODOLOGY 3

4 CLASSIFICATION DEFINITIONS 4

4.1 Risk Classifications 4

5 ASSESSMENT FINDINGS/REPORT 5

1 Executive Summary

MOL-IT IST(Information Security Team) performed a security assessment of the MOL SAME Website for period 04-July-25 to 15-July-25. MOL-IT IST Team's penetration test simulated an attack from an external threat actor attempting to gain access to systems. The purpose of this assessment was to discover and identify and suggest methods to remediate the vulnerabilities. IST Team identified a total of 10 vulnerabilities within the scope of the engagement which are broken down by severity in the table below.

CRITICAL	HIGH	MEDIUM	LOW
0	2	5	3

In order to ensure data confidentiality, integrity and availability, security remediations should be implemented by development/patching team.

2 Scope

All testing was based on the scope as defined in the Request For Proposal (RFP) and official written communications. The item in scope is listed below.
https://mol-same.com/

3 TESTING METHODOLOGY

MOL-IT IST's testing methodology was split into following phases

- Reconnaissance: During reconnaissance, we gathered information about application. Team used port scanning and other enumeration methods to refine target information and assess target values
- Target Assessment: Next, we conducted our targeted assessment using manual and automated Tool based techniques.
- Execution of Vulnerabilities: Team tried simulating an attacker exploiting and gathered evidence of vulnerabilities during this phase of the engagement while conducting the simulation in a manner that would not disrupt normal business operations.
- Analysis: Team did risk-based analysis by categorizing the vulnerabilities in various categories based on impact.
- Reporting: This is the final phase where team prepared the detailed vulnerabilities report on targeted application.

The following image is a graphical representation of VAPT process :

4 CLASSIFICATION DEFINITIONS

4.1 Risk Classifications

Level	Score	Description
Critical	**10**	The vulnerability poses an immediate threat to the organization. Successful exploitation may permanently affect the organization. Remediation should be immediately performed.
High	**7-9**	The vulnerability poses an urgent threat to the organization, and remediation should be prioritized.
Medium	**4-6**	Successful exploitation is possible and may result in notable disruption of business functionality. This vulnerability should be remediated when feasible.
Low	**1-3**	The vulnerability poses a negligible/minimal threat to the organization. The presence of this vulnerability should be noted and remediated if possible.
Informational	**0**	These findings have no clear threat to the organization, but may cause business processes to function differently than desired or reveal sensitive information about the company.

5 ASSESSMENT FINDINGS/REPORT

Sno.	Vulnerabilities	Impact	Risk	Risk score	Remediation
1	Web.config File Information Disclosure	An information disclosure vulnerability exists in the remote web server due to the disclosure of the web.config file. An unauthenticated, remote attacker can exploit this, via a simple GET request, to disclose potentially sensitive configuration information.	High	8	Restrict access to web.config
2	Injection attack leading to sensitive information disclosure	Website is vulnerable to cross site scripting and SQL injection attack	High	8	Escape user input; use Content Security Policy (CSP); validate input, Use prepared statements (parameterized queries)
3	Web Application Information Disclosure	The remote web application discloses path information	Medium	5	Customize error pages. Hide internal paths and stack traces. Log errors privately and securely.
4	Web Application Potentially Vulnerable to Clickjacking	The remote web server may fail to mitigate a class of web application vulnerabilities. Clickjacking deceives users into clicking hidden UI elements. Can lead to serious unauthorized actions on trusted sites	Medium	5	Return the X-Frame-Options or Content-Security-Policy (with the 'frame-ancestors' directive) HTTP header with the page's response. This prevents the page's content from being rendered by another site when using the frame or iframe HTML tags.

5	HSTS Missing From HTTPS Server (RFC 6797)	The remote web server is not enforcing HSTS, as defined by RFC 6797. HSTS is response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks,SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.	Medium	5	Configure the remote web server to use HSTS.
6	Un necessary services/ports are opened such as port 25(SMTP) and port 53(DNS)	Email spoofing/email based DDoS/spam mails. DNS Amplification (DDoS)/The remote DNS server could be used in a distributed denial of service attack.	Medium	5	Block/disabled un-necessary ports, Restrict access to your DNS server from public network or reconfigure it to reject such queries
7	Web server running Multiple CGI scripts which is vulnerable to the 'shellshock' vulnerability CVE-2014-6271	Shellshock, also known as "Bash Bug", is a critical remote code execution (RCE) vulnerability that was discovered in GNU Bash (Bourne Again Shell) in September 2014. if exploited, Full remote code execution (attacker can run any command on your server)	Medium	5	Update Bash to the latest version, Patched versions are ≥ 4.3 with security patches (or 5.x+)
8	Outdated jquery version 3.4.1	May introduce XSS attack as an attacker can exploit this by injecting malicious scripts through user-supplied HTML.	Low	3	Upgrade to the latest stable jQuery version (3.6.4+ as of 2025) where this XSS vulnerability is patched
9	Apache version 2.4.52 is outdated	Outdated Apache version may introduce Remote Code Execution (RCE) vulnerability	Low	3	Upgrade to Apache 2.4.53 or later
10	Contact us page is vulnerable	Input fields of contact us page is accepting the malicious script which may introduce injection attack such as cross site scripting	Low	3	Perform input parameter sanitization/validation